

# Hallazgos de análisis externo — ERSO 2026-003

- Hallazgos de análisis externo — ERSO 2026-003
  - Creación del DID y DID Document del titular
  - 1. Resumen
  - 2. Proyectos citados en este informe
  - 3. Hallazgos
  - 4. Aplicación a los criterios de aceptación de la ERSO 003
  - 5. Diferencias de diseño frente a nuestro proyecto
  - 6. Qué aprender y qué hacer con esto
  - 7. Límites de este informe

# Hallazgos de análisis externo — ERSO 2026-003

## Creación del DID y DID Document del titular

|                        |                                                                                                                                              |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Proyecto propio        | Identidad Digital Soberana SSI ( /home/geovani/Descargas/generic/bitacora/new_proyect )                                                      |
| Fecha del análisis     | 2 de octubre de 2026                                                                                                                         |
| Carpetas analizadas    | /home/geovani/Workspace/Wallet/Wallet, .../Verifier, .../Issuer, .../Trust, .../librerias                                                    |
| Versión del informe    | Actualizado el 2 de octubre de 2026: se añaden los hallazgos de la carpeta librerias y el análisis a fondo del gestor de listas de confianza |
| Cobertura de esta ERSO | Baja (almacenamiento y políticas de clave por credencial)                                                                                    |
| Método                 | Lectura de código y documentación; no se compiló ni se ejecutó ninguno de los proyectos externos                                             |

## 1. Resumen

La ERSO 003 trata de crear **en el dispositivo** el DID y el DID Document del titular. Ninguno de los proyectos externos crea ni usa DID del titular: en el ecosistema de referencia el titular se identifica por la clave contenida en la credencial ( cnf ) y no por un DID. Lo aplicable es el **almacenamiento cifrado** con clave del Keystore y la idea de enlazar la credencial a una clave del titular. **Complemento (carpeta librerias)**: las bibliotecas no crean un DID del titular, pero muestran dos mecanismos que atienden el riesgo de privacidad de nuestro informe: **una clave por credencial** y políticas de **uso único o rotación**, y una validación de la sintaxis de DID con codificación porcentual.

## 2. Proyectos citados en este informe

| Carpeta   | Proyecto                                 | Qué es                                                                                                       |
|-----------|------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Wallet    | av-app-android-wallet-ui                 | App Android de verificación de edad (versión derivada de la anterior); incluye el módulo vdr-extension-logic |
| Wallet    | eudi-app-android-wallet-ui               | App Android de la cartera EUDI (referencia)                                                                  |
| Verifier  | eudi-srv-verifier-endpoint               | Backend verificador (Kotlin/Spring)                                                                          |
| Issuer    | eudi-srv-pid-issuer                      | Emisor de credenciales (Kotlin/Spring)                                                                       |
| librerias | eudi-lib-android-wallet-document-manager | Gestor de documentos de la cartera (estados, políticas de credencial, claves)                                |
| librerias | eudi-lib-jvm-openid4vci-kt               | Biblioteca de OpenID4VCI 1.0 (emisión, DPoP, attestation, diferida, notificación)                            |
| librerias | eudi-lib-jvm-openid4vp-kt                | Biblioteca de OpenID4VP (autenticación del verificador, cifrado de respuesta, DID)                           |
| librerias | eudi-lib-android-wallet-core             | Biblioteca Android de la cartera EUDI: claves, documentos, confianza, estado, registro de transacciones      |

## 3. Hallazgos

La columna *Criterio* indica a qué criterio de aceptación de la ERSO se aplica el hallazgo (el detalle está en la sección 4).

| # | Proyecto<br>(carpeta/proyecto)                                       | Archivo o lugar                                                                                                                                   | Qué se encontró                                                                                                                                                                                                                     | Relación con<br>nuestro proyecto                                                                                                                     | Criterio                            |
|---|----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|
| 1 | Wallet/av-app-android-wallet-ui<br>Wallet/eudi-app-android-wallet-ui | (búsqueda en todo el proyecto)                                                                                                                    | No se encontraron referencias a <code>did:web</code> , <code>did:key</code> ni <code>DidDocument</code> en el código de la app salvo en el módulo VDR de <code>av-app-android-wallet-ui</code> (que es del lado del registro).      | La creación del DID del titular en la cartera es propia de nuestro proyecto.                                                                         | C1, C3                              |
| 2 | Wallet/av-app-android-wallet-ui                                      | <code>business-logic/.../controller/storage/SecurePrefsStore.kt</code> y <code>.../crypto/CryptoController.kt</code>                              | Almacenamiento de preferencias cifrado con AES-GCM y clave del Keystore.                                                                                                                                                            | Análogo a nuestro <code>SealedDocumentStore</code> , <b>sin</b> ligar el cifrado a la instancia ni al identificador (no usa AAD, según lo revisado). | C4                                  |
| 3 | Wallet/av-app-android-wallet-ui                                      | <code>authentication-logic/.../storage/BiometryStorageController.kt</code> , <code>PinStorageProviderImpl.kt</code>                               | Cofre protegido por biometría y por PIN.                                                                                                                                                                                            | Almacén protegido por autenticación del usuario; nuestro almacén no depende de ella.                                                                 | C4                                  |
| 4 | Verifier/eudi-srv-verifier-endpoint                                  | <code>.../adapter/out/sdjwvc/SdJwtVcValidator.kt</code>                                                                                           | El verificador usa la clave de <code>cnf</code> (clave del titular) y exige KB-JWT; no usa un DID del titular. Existe el código de error <code>UnableToLookupDID</code> pero no se encontró una configuración que resuelva DID.     | El titular se identifica por la clave de la credencial; nuestro DID del titular sería un identificador adicional.                                    | C3                                  |
| 5 | Issuer/eudi-srv-pid-issuer                                           | <code>.../adapter/out/proof/ValidateJwtProofWithKeyAttestation.kt</code>                                                                          | El emisor liga la credencial a las claves <b>atestiguadas</b> del titular.                                                                                                                                                          | Equivale a la clave pública del titular en <code>cnf</code> ; no requiere DID.                                                                       | C3                                  |
| 6 | librerias/eudi-lib-android-wallet-document-manager                   | <code>document-manager/.../CreateDocumentSettings.kt</code> ( <code>numberOfCredentials</code> , <code>credentialPolicy</code> )                  | Cada documento puede tener varias credenciales, cada una con su clave, con política <code>RotateUse</code> (por defecto) o <code>OneTimeUse</code> .                                                                                | Mitiga la correlación por clave/identificador fijo: justo el riesgo que declara nuestro informe al publicar un DID persistente del titular.          | Fuera de los criterios (privacidad) |
| 7 | librerias/eudi-lib-jvm-openid4vci-kt                                 | <code>.../openid4vci/CredentialReusePolicy.kt</code> ; <code>application.properties</code> del emisor ( <code>batchIssuance.batchSize=20</code> ) | Emisión por lotes con política de reutilización.                                                                                                                                                                                    | Alternativa de diseño: varios identificadores de corta vida en lugar de un DID persistente.                                                          | Fuera de los criterios (privacidad) |
| 8 | librerias/eudi-lib-jvm-openid4vp-kt                                  | <code>src/main/kotlin/.../openid4vp/internal/DID.kt</code>                                                                                        | Expresiones regulares de sintaxis de DID y de DID URL: <code>did:&lt;método&gt;</code> con segmentos separados por <code>:</code> y caracteres <code>A-Z a-z 0-9 . - _ o %XX</code> ; el DID URL admite ruta, consulta y fragmento. | Referencia para la comprobación C01 del informe de conformidad; nuestro validador acepta un DID con <code>%3A</code> para el puerto.                 | C2                                  |

| #  | Proyecto (carpeta/proyecto)                        | Archivo o lugar                                                                             | Qué se encontró                                                                                                  | Relación con nuestro proyecto                                                              | Criterio |
|----|----------------------------------------------------|---------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|----------|
| 9  | librerias/eudi-lib-android-wallet-document-manager | document-manager/.../DocumentManager.kt<br>( Builder.setStorage , setSecureAreaRepository ) | El almacenamiento del documento y las claves se inyectan por separado: datos en Storage , claves en SecureArea . | Separación equivalente a nuestro almacén sellado (datos) y custodio (clave).               | C4       |
| 10 | librerias/eudi-lib-android-wallet-core             | wallet-core/.../provider/DefaultWalletKeyManager.kt                                         | Almacenamiento en noBackupFilesDir (no se incluye en copias de seguridad).                                       | Idea aplicable al archivo sellado de nuestro almacén: excluirlo de las copias del sistema. | C4       |

## 4. Aplicación a los criterios de aceptación de la ERSO 003

Para cada criterio: lo que exige el PDF de la ERSO, dónde está nuestra evidencia y qué hallazgos externos se le aplican.

### Criterio 1. El DID y su DID Document se generan en el dispositivo sin exponer la clave privada.

|                            |                                                                                                                                                                                      |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidencia que pide la ERSO | Registro de generación.                                                                                                                                                              |
| Nuestra evidencia          | INFORME-FINAL-ERSO-2026-003 §16                                                                                                                                                      |
| Hallazgos aplicables       | #1 ( Wallet/av-app-android-wallet-ui , Wallet/eudi-app-android-wallet-ui )                                                                                                           |
| Qué aporta el análisis     | Ningún proyecto externo crea un DID del titular: la creación local es original de nuestro proyecto. El ecosistema de referencia identifica al titular por la clave de la credencial. |

### Criterio 2. El DID Document es conforme al modelo de datos de W3C DIDs v1.1.

|                            |                                                          |
|----------------------------|----------------------------------------------------------|
| Evidencia que pide la ERSO | Informe de conformidad.                                  |
| Nuestra evidencia          | INFORME-FINAL-ERSO-2026-003 §17                          |
| Hallazgos aplicables       | #8 ( librerias/eudi-lib-jvm-openid4vp-kt )               |
| Qué aporta el análisis     | No se encontró nada aplicable en los proyectos externos. |

### Criterio 3. Las relaciones de verificación apuntan a la clave pública Multikey del titular.

|                            |                                                                                                                                                           |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidencia que pide la ERSO | Documento generado.                                                                                                                                       |
| Nuestra evidencia          | INFORME-FINAL-ERSO-2026-003 §18                                                                                                                           |
| Hallazgos aplicables       | #1 ( Wallet/av-app-android-wallet-ui , Wallet/eudi-app-android-wallet-ui ); #4 ( Verifier/eudi-srv-verifier-endpoint ); #5 ( Issuer/eudi-srv-pid-issuer ) |
| Qué aporta el análisis     | Lo más cercano es la clave del titular enlazada a la credencial ( cnf ), que el verificador y el emisor usan en lugar de un DID.                          |

### Criterio 4. El documento queda almacenado de forma no exportable y asociado a la instancia de cartera.

|                            |                                                                                                                                                                                                                                                                                                         |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidencia que pide la ERSO | Prueba de almacenamiento.                                                                                                                                                                                                                                                                               |
| Nuestra evidencia          | INFORME-FINAL-ERSO-2026-003 §19                                                                                                                                                                                                                                                                         |
| Hallazgos aplicables       | #2 ( Wallet/av-app-android-wallet-ui ); #3 ( Wallet/av-app-android-wallet-ui ); #9 ( librerias/eudi-lib-android-wallet-document-manager ); #10 ( librerias/eudi-lib-android-wallet-core )                                                                                                               |
| Qué aporta el análisis     | La app de verificación de edad guarda datos cifrados con una clave del Keystore y tiene cofres protegidos por biometría y PIN: sirve para comparar con nuestro almacén sellado. Las bibliotecas separan el almacenamiento de datos de las claves y colocan el archivo fuera de las copias de seguridad. |

## 5. Diferencias de diseño frente a nuestro proyecto

| Tema                                      | Proyectos externos                          | Nuestro proyecto                                              |
|-------------------------------------------|---------------------------------------------|---------------------------------------------------------------|
| Identificador del titular                 | Clave pública en <code>cnf</code> ; sin DID | <code>did:web:&lt;dominio&gt;;titulares:&lt;huella&gt;</code> |
| Publicación del identificador del titular | No existe                                   | Opcional, por el Wallet Backend en el VDR                     |
| Informe de conformidad del documento      | No aplica                                   | 10 comprobaciones (C01 a C10)                                 |
| Almacén local                             | Cifrado con clave del Keystore              | Cifrado con AAD (instancia y DID)                             |

## 6. Qué aprender y qué hacer con esto

- Este hallazgo respalda el riesgo de privacidad declarado en nuestro informe 003: el ecosistema de referencia **evita** un identificador público persistente del titular.
- Decisión de producto pendiente: mantener la publicación opcional del DID del titular o alinear con el modelo sin DID (identificación solo por `cnf`).
- Si se conserva el DID, estudiar el cifrado del almacén de `av-app-android-wallet-ui` (`CryptoController`) para comparar con nuestro `SealedDocumentStore`.
- Decisión de producto: evaluar una política de claves de uso único o rotación por credencial, ya disponible en las bibliotecas, como alternativa al DID persistente del titular.
- Mejora posible: ubicar el archivo sellado de la cartera en un directorio excluido de copias de seguridad.

## 7. Límites de este informe

- Todo proviene de **lectura de código**; el comportamiento real no se verificó ejecutando.
- Se citan archivos y, cuando se anotó, números de línea (con `~` si son aproximados); las versiones de los proyectos son las que había en disco el 2 de octubre de 2026.
- "No encontré" significa que las búsquedas realizadas no lo hallaron, no que no exista en ninguna parte del código.
- Los proyectos de referencia EUDI se declaran a sí mismos como versiones de desarrollo no aptas para producción.